

Manual 32 — Implementación controlada FFIEC

****Idioma:**** Español de América Latina (es-419)

****Línea base controlada:**** materiales activos del FFIEC Information Technology Examination Handbook y overlays aplicables de sus agencias miembros, reverificados el 31 de agosto de 2026.

****Límite:**** el Handbook FFIEC es guía interagencial de examen. No es una ley federal autónoma ni sustituye leyes, regulaciones u órdenes vinculantes, hallazgos de supervisión específicos de una institución ni análisis jurídico/regulatorio calificado. El FFIEC Cybersecurity Assessment Tool (CAT) fue retirado el 31 de agosto de 2025 y no se utiliza como línea base vigente.

Chapter 01 — Propósito, alcance y jerarquía controlada de fuentes

Use los booklets vigentes del FFIEC IT Handbook como fuentes de guía de examen y mantenga referencias separadas para leyes, regulaciones, reglas/órdenes de agencias, declaraciones de supervisión y compromisos específicos. Los ejemplos internos no son diseños aprobados por reguladores.

Chapter 02 — Tipo de institución, charter, regulador y aplicabilidad

Mantenga una matriz que identifique tipo de institución, charter, regulador federal primario, regulador estatal cuando corresponda, entidades, servicios, roles como technology service provider y overlays relevantes. No infiera requisitos de examen por una etiqueta genérica.

Chapter 03 — Modelo de gobierno FFIEC y supervisión del board

Convierta los conceptos de gobierno FFIEC en responsabilidades definidas de board/alta gerencia, reporting, escalamiento, asignación de recursos, aprobación de políticas y challenge. Conserve evidencia de supervisión informada de riesgo IT/cibernético.

Chapter 04 — Integración con enterprise risk management

Integre riesgo IT y cibernético con ERM mediante taxonomía, apetito/tolerancia, propietarios, escalamiento, riesgo de concentración, riesgo emergente y disparadores de cambio. Preserve diferencias entre guía de supervisión y requisitos vinculantes.

Chapter 05 — Gobierno del information-security program

Mantenga un programa de seguridad de la información conectado a risk assessment, gobierno, controles, operaciones, incident response, pruebas y mejora. Mapee por separado Interagency Information Security Standards y requisitos específicos de agencias.

Chapter 06 — Gobierno de arquitectura e infraestructura IT

Mantenga arquitectura actual de sistemas, plataformas, redes, cloud, data flows, dependencias, resiliencia, trust boundaries y terceros. Las decisiones deben evaluarse por riesgo, aprobarse, ser trazables y estar disponibles para examen con detalle apropiado.

Chapter 07 — Operaciones tecnológicas y service management

Gobierne producción mediante propietarios, monitoreo, procesos, capacidad, disponibilidad, eventos, problemas, service levels, backup, operaciones privilegiadas y registros. La evidencia debe demostrar operación sostenida, no solo intención de política.

Chapter 08 — Gobierno de desarrollo, adquisición y mantenimiento

Aplique el booklet FFIEC Development, Acquisition, and Maintenance de 2024 a planificación, adquisición, SDLC, proyecto, mantenimiento, supply-chain risk, seguridad, resiliencia y ciclo de vida. Separe responsabilidades internas y de proveedores.

Chapter 09 — Change y configuration management

Controle cambios con autorización, riesgo, pruebas, segregación de funciones, emergency changes, baselines, evidencia de deployment, rollback y post-implementation review. Vincule cambios fallidos/no autorizados a issue management.

Chapter 10 — Inventario de activos y ciclo de vida tecnológico

Mantenga inventarios de hardware, software, aplicaciones, infraestructura, cloud, datos, dependencias, propietarios, criticidad, soporte y ciclo de vida. Identifique tecnología unsupported/end-of-life y documente tratamiento, migración o excepción aprobada.

Chapter 11 — Identity governance y administración de acceso

Defina ciclo de identidad, provisioning, roles, aprobación, least privilege, recertificación, traslado/baja, service accounts, usuarios externos y excepciones. Concilie directorios y entitlements con fuentes autoritativas.

Chapter 12 — Authentication y privileged access

Use autenticación basada en riesgo y controles reforzados para acceso privilegiado, remoto, de alto riesgo o sensible. Documente MFA/equivalentes, PAM, protección de credenciales, monitoreo, emergencia y compensating controls.

Chapter 13 — Clasificación de datos, protección y criptografía

Clasifique información por sensibilidad, requisitos legales, impacto, obligaciones al cliente y retención. Aplique acceso, cifrado, key management, transferencia, masking, disposición, backup y monitoreo según riesgo y obligaciones.

Chapter 14 — Seguridad de red, endpoint e infraestructura

Implemente controles en segmentación, firewalls, remote access, endpoint protection, hardening, wireless, correo/web, interfaces administrativas, cloud networking e infraestructura. Mantenga diagramas, baselines, excepciones y monitoreo.

Chapter 15 — Logging, monitoring, detección y security analytics

Defina fuentes de eventos, centralización, retención, alertas, tuning, escalamiento, responsabilidades, investigaciones y validación de cobertura. El diseño debe reflejar activos críticos, amenazas, obligaciones y perfil de riesgo.

Chapter 16 — Vulnerability, patch y exposure management

Opere descubrimiento, evaluación, priorización, patching, remediación de configuración, exposición externa, excepciones y verificación. Gestione exposiciones vencidas mediante aceptación documentada y controles compensatorios.

Chapter 17 — Software seguro y controles de aplicaciones

Aplique diseño seguro, requisitos, coding, code review, testing, dependencia/SBOM o controles equivalentes cuando sean apropiados, secrets management, release, mantenimiento y remediación. Separe controles de la institución de responsabilidades del proveedor.

Chapter 18 — Cloud, virtualización y tecnología emergente

Evalúe cloud, SaaS, containers, virtualización, IA, automatización, APIs y otras tecnologías por arquitectura, datos, identidad, resiliencia, terceros, concentración, exit, seguridad y compliance. La assurance del proveedor no elimina accountability institucional.

Chapter 19 — Supervisión de terceros y technology service providers

Mantenga due diligence, contratos, requisitos de seguridad, revisión de desempeño/assurance, acceso, incidentes, resiliencia, subcontratistas, terminación y exit. Aplique separadamente requisitos legales o de agencia para TSP.

Chapter 20 — Outsourcing y riesgo de concentración

Evalúe concentración operativa, geográfica, sistémica, cloud, proveedor, plataforma, habilidades, datos y recuperación. Defina tolerancia, contingencia, alternativas, factibilidad de exit, escalamiento y monitoreo.

Chapter 21 — Cybersecurity incident response y escalamiento

Mantenga gobierno de incidentes para detección, triage, severidad, contención, erradicación, recuperación, evidencia, comunicaciones, análisis legal/regulatorio, impacto, terceros, lecciones y remediación. Pruebe decisiones y dependencias.

Chapter 22 — Notificación regulatoria y decisiones de overlays de agencia

Mantenga matriz de obligaciones por regulador, norma, tipo de evento, umbral, plazo, método y propietario. Conserve hechos, timestamps, análisis, autoridad, filing y suplementos; la severidad interna no sustituye un trigger legal.

Chapter 23 — Business continuity y disaster recovery

Use el FFIEC Business Continuity Management vigente para continuidad empresarial, recovery tecnológico, comunicaciones, dependencias, crisis y pruebas. Vincule BIA, objetivos, planes, tests, hallazgos y remediación a servicios críticos.

Chapter 24 — Operational resilience y scenario testing

Pruebe escenarios severos pero plausibles de cyber, tecnología, terceros, instalaciones, personal, datos y dependencias externas. Defina objetivos, supuestos, decisiones, targets, lecciones, propietarios y mejoras.

Chapter 25 — Backup, recovery y restoration assurance

Gobierne alcance, frecuencia, protección immutable/offline cuando corresponda, acceso, cifrado, retención, monitoreo, restauración, dependencias y pruebas. Demuestre recoverability mediante restores exitosos y remediación de fallas.

Chapter 26 — Interfaces de seguridad física y ambiental

Coordine IT/cyber con instalaciones, energía, cooling, incendio, physical access, vigilancia, data centers, monitoreo ambiental y sitios alternos. Identifique responsabilidades compartidas y evidencia de instalaciones propias/tercerizadas.

Chapter 27 — Awareness y capacitación basada en rol

Proporcione awareness base y capacitación para usuarios privilegiados, developers, admins, incident responders, ejecutivos, board, third-party managers y roles relevantes. Mantenga contenido, población, finalización, excepciones, efectividad y cambios por riesgo.

Chapter 28 — Pruebas independientes, auditoría y assurance

Defina assurance independiente según riesgo, ley y expectativas de supervisión. Conserve alcance, independencia, método, población/muestra, hallazgos, ratings, respuesta, validación de remediación y límites de confianza en informes de terceros.

Chapter 29 — Examination readiness y gestión de evidencia

Mantenga índice de evidencia que vincule solicitudes a políticas, procedimientos, inventarios, assessments, gobierno, controles, pruebas, issues y propietarios. Entregue evidencia actual y conciliada y explique gaps o artefactos superados.

Chapter 30 — Issue management, remediación y aceptación de riesgo

Gestione issues de examen, auditoría, control, riesgo, incidentes y testing con fuente, severidad, causa, propietario, fecha, controles interinos, validación y cierre. La aceptación de riesgo no puede anular obligaciones vinculantes o compromisos supervisores.

Chapter 31 — Métricas, reporting, trazabilidad supervisora y mejora

Defina métricas con fórmula, fuente, población, frecuencia, propietario, threshold, exclusiones y acción. El reporting debe conectar riesgos/issues con decisiones y remediación; maturity scores o conteos no prueban compliance.

Chapter 32 — Reverificación de fuentes y roadmap de implementación

Antes de cada release, revalide FFIEC IT Handbook, guías/reglas de agencias, requisitos legales y desarrollos de examen. Confirme explícitamente que el CAT retirado sigue no vigente y evalúe sucesores, revisiones de booklets y cambios regulatorios.

Conjunto mínimo de evidencia

Mantenga, según aplique: matriz regulador/aplicabilidad; supervisión board/gerencia; security program; risk assessment; arquitectura/inventario; accesos; authentication/PAM; datos; red/endpoint; logging; vulnerabilidades/patch; desarrollo/cambio; cloud/emerging tech; TSP/outsourcing/concentration; incidentes/notificaciones; BCM/DR/restores; instalaciones; training; assurance independiente; índice de examen; issues/risk acceptance; métricas/reporting; y verificación de fuentes.